CTF Writeup: Portable Document Forensics

Files: PBES-512.pdf + flag3.zip
Category: PDF Forensics / Steganography
Flag: `SK-CERT{WHY_15_MJ_3V3RYWH3R3}`
Password Order: 4-3-2-1 (MSG_4 + MSG_3 + MSG_2 + MSG_1)

1. Overview & Reconnaissance

The challenge centers around `PBES-512.pdf`, a 15-page document detailing the "Poultry-Based Encryption Standard." We must extract four 8-character hex values (MSG_1 through MSG_4) hidden across various PDF layers and assemble them in the reverse order **4321** to unlock `flag3.zip`.

Initial Triage

```
# Inspecting PDF structure with pypdf Pages: 15 Metadata: {'/Title': 'PBES-512', '/Author': 'The Coop Council', '/Producer': 'LaTeX with hyperref'} Key observations: PDF 1.5, only 14 pages visible in some viewers; Page 15 is referenced but contains no renderable text.
```

2. Deep Dive: Hidden Message Extraction

Part 1: Glyph Overlay Steganography (MSG_1 = 4abcc69f)

Location: Page 12, within the "Certificate of Authenticity" signature box.

- **Technique:** Character glyphs were placed as individual Image XObjects overlaid directly on the signature line. They were rendered with 99% transparency and a scale of 0.1, making them invisible during normal viewing.
- **Detection:** Running `pdf-parser -t XObject PBES-512.pdf` revealed a series of images (Objects 45-52) that were not part of the standard document branding.
- **Extraction:** Using `mutool extract` to pull the images confirmed they were tiny renders of the hex characters.

Part 2: Off-Screen Annotation (MSG_2 = b100bf91)

Location: Page 14 (The "Hidden" empty page).

- **Technique:** A `FreeText` annotation (Type /Annot) was created with coordinates far outside the `/MediaBox` boundaries (specifically `[-5000, -5000]`).
- **Detection:** Programmatic scanning of the `/Annots` dictionary for Page 14 revealed the hidden object.
- **Extraction:**

```
# pypdf extraction logic page = reader.pages[13] for annot in page['/Annots']: obj = annot.get_object() print(obj['/Contents']) # Result: HIDDEN_MSG_2_{b100bf91}
```

Part 3: X.509 SAN Extension (MSG_3 = 0a6899cf)

Location: Embedded Intermediate CA Certificate.

- **Technique:** The PDF contains an embedded Digital Signature. Inspecting the certificate chain revealed an Intermediate CA used for "Coop-Level Validation."
- **Detection:** Use `pdf-parser` to find stream objects containing the "Begin Certificate" header.
- **Extraction:**

```
openssl x509 -in extracted_cert.crt -text -noout # Result found in Subject Alternative Name (SAN): # DNS:pbes512.msg3.0a6899cf.internal
```

Part 4: Nested File Attachment (MSG_4 = 85add2c0)

Location: PDF Embedded Files (EmbeddedFiles / Names).

- **Technique:** A ZIP file (`attachment.zip`) was attached to the PDF structure via the `/EmbeddedFiles` entry in the Document Root.
- **Extraction:** The attachment was extracted using `pdfdetach -saveall`. Inside the ZIP was a text file titled `key_part_4.txt`.
- **Value:** `85add2c0`

3. Final Password & Flag

Following the assembly order **4-3-2-1**:

Part	Hex Value	Technique
MSG_4	`85add2c0`	Nested ZIP Attachment
MSG_3	`0a6899cf`	X.509 Certificate SAN Extension
MSG_2	`b100bf91`	Off-screen FreeText Annotation
MSG_1	`4abcc69f`	Glyph Overlays (XObjects)

```
Password: 85add2c00a6899cfb100bf914abcc69f
```

Applying this password to `flag3.zip` reveals the flag: `SK-CERT{WHY_15_MJ_3V3RYWH3R3}`

Bonus: Is PBES-512 a real encryption standard?

No. PBES-512 ("Poultry-Based Encryption Standard") is an elaborate joke document. The flag itself — "WHY IS MJ EVERYWHERE" in leetspeak — confirms its humorous intent. The document is a well-crafted parody of real cryptographic standard papers (complete with correct LaTeX-style math notation and proper threat model structure), but every concrete technical claim involves chickens.

Dead Giveaways:

- **Authors:** Dr. Henrietta K. Fowler (fowl), Prof. Clive R. Hatchman (hatch), and Dr. Amelia Eggsworth (eggs) from the *Institute for Avian Security Standards (IASS)*.
- **Algorithm:** Entropy sourced from "spontaneous cluck emission patterns" with a minimum sampling rate of 128 clucks/sec per "ISO-Hen-27001."
- **Mechanisms:** Key derivation via "FeatherHash512" and forward secrecy achieved through "Molting Rotation."
- **Threat Model:** Defends against "Q-Roosters" (quantum roosters running Grover's algorithm) and assumes attackers do not possess "Certified Feather Injection Hardware (FIH)."
- **Compliance:** Specifically targets "farm-to-cloud" deployment environments.

4. Tools & Methodology

- **pdf-parser:** Essential for navigating the object-oriented structure of the PDF.
- **mutool:** Used for resource extraction (images/fonts).

- **openssl:** Required for the analysis of embedded cryptographic certificates.
- **pdfdetach:** Specialized tool for extracting hidden file attachments.